

AI-Assisted Governance for Post-Quantum Cryptography Migration in Government Digital Infrastructure: A Research Framework

Prince (Rhyugen) *Offensive Security Engineer & Theoretical Researcher Quantum Blue Research Initiative*

Abstract

Central Research Question: *Can an AI-assisted governance framework improve the adoption, standardization, and secure migration of post-quantum cryptography (PQC) in government digital infrastructure, compared to traditional top-down policy approaches?*

The transition from classical to post-quantum cryptographic standards—driven by NIST’s recent standardization of ML-KEM and ML-DSA—presents a critical challenge for government digital infrastructure worldwide. Unlike private-sector systems, government migration involves heterogeneous legacy systems, inter-agency coordination, regulatory compliance, and national security constraints that resist purely technical solutions. This paper proposes a research framework for an AI-assisted governance model that combines automated cryptographic inventory, risk-based prioritization, policy simulation, and compliance monitoring to accelerate PQC adoption while maintaining security guarantees. We identify a research gap: existing PQC migration literature focuses almost exclusively on technical algorithm replacement, with minimal attention to the governance, policy, and organizational dimensions of large-scale cryptographic transitions. We present four hypotheses, a layered research model, a detailed methodology, and a validation roadmap. This paper contributes a formal research framework rather than validated experimental results.

Keywords: Post-Quantum Cryptography, Governance, AI-Assisted Policy, Government Digital Infrastructure, NIST Standards, Cryptographic Migration, Risk Management

1. Introduction

1.1 The PQC Transition Imperative

In 2024, NIST finalized its first set of post-quantum cryptographic standards: ML-KEM (FIPS 203) for key encapsulation and ML-DSA (FIPS 204) for digital signatures [NIST, 2024]. These standards replace classical RSA and ECC algorithms, which will be broken by sufficiently large quantum computers using Shor’s algorithm [Shor, 1994]. The “harvest now, decrypt later” threat—where adversaries collect encrypted data today to decrypt once quantum computers become available—creates urgency for immediate migration [Mosca, 2018].

Government digital infrastructure faces unique challenges:

- **Heterogeneous legacy systems:** Decades-old systems with hardcoded cryptographic dependencies
- **Inter-agency coordination:** Multiple departments with independent procurement and deployment cycles

- **Regulatory compliance:** Mandatory adherence to national standards (e.g., FIPS, Common Criteria)
- **National security constraints:** Classified systems with air-gapped requirements
- **Budget and timeline pressures:** Fixed fiscal cycles and election-driven priority shifts

1.2 The Governance Gap

Existing PQC migration literature focuses predominantly on technical dimensions:

Category	Existing Work	Gap
Algorithm design	Lattice-based, hash-based, code-based PQC [Bernstein & Lange, 2017]	Well-studied
Implementation	liboqs, Bouncy Castle PQC, OpenSSL PQC [Open Quantum Safe, 2024]	Active development
Performance benchmarking	Key/signature sizes, computation time [Sikeridis et al., 2020]	Extensive
Governance & policy	Minimal academic attention	This paper addresses
Migration frameworks	Vendor-specific guides; no unified model	This paper addresses
AI-assisted coordination	Not studied	This paper addresses

The critical gap is that PQC migration is not merely a technical problem of replacing algorithms. It is a **governance problem** involving risk assessment, resource allocation, stakeholder coordination, compliance verification, and continuous monitoring across thousands of systems. No existing framework addresses the intersection of AI-assisted governance, policy simulation, and cryptographic migration at national scale.

1.3 Central Research Question and Sub-Questions

RQ: Can an AI-assisted governance framework improve the adoption, standardization, and secure migration of post-quantum cryptography in government digital infrastructure, compared to traditional top-down policy approaches?

RQ1: Can automated cryptographic inventory and dependency mapping accurately identify PQC-vulnerable systems in heterogeneous government infrastructure?

RQ2: Can AI-driven risk-based prioritization outperform manual risk assessment in allocating migration resources?

RQ3: Can policy simulation models predict migration bottlenecks and compliance gaps before they occur?

RQ4: Can continuous automated compliance monitoring maintain security guarantees during the multi-year transition period?

1.4 Contributions

1. **A formal research model** (Section 2) that frames PQC migration as a governance problem requiring AI-assisted coordination.
 2. **A layered governance framework** (Section 3) with four components: automated inventory, risk prioritization, policy simulation, and compliance monitoring.
 3. **Hypotheses and validation roadmap** (Section 4) for empirical testing against traditional migration approaches.
 4. **A discussion of policy implications** (Section 5) for national-level PQC transitions.
-

2. Theoretical Framework

2.1 Why AI-Assisted Governance?

Traditional top-down governance models for large-scale IT transitions suffer from three limitations:

1. **Information asymmetry:** Central planners lack visibility into local system configurations, dependencies, and constraints.
2. **Static planning:** Fixed migration timelines cannot adapt to emerging threats, budget changes, or technical discoveries.
3. **Compliance lag:** Manual auditing cannot keep pace with continuous system changes during multi-year transitions.

AI-assisted governance addresses these limitations through:

- **Automated discovery:** Machine learning models scan codebases, network traffic, and configuration files to build real-time cryptographic inventories.
- **Dynamic optimization:** Reinforcement learning adjusts migration priorities based on evolving risk landscapes.
- **Continuous verification:** Automated compliance checking replaces periodic manual audits.

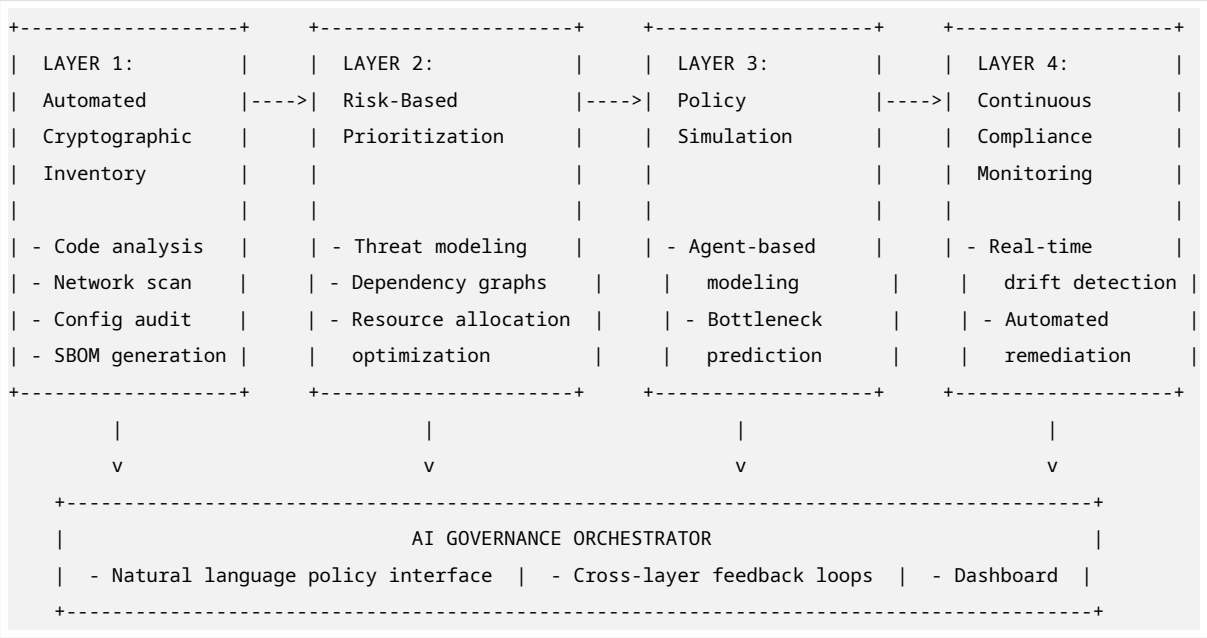
2.2 Foundational Assumptions

Assumption	Justification	Supporting Literature
A1: Government infrastructure contains discoverable cryptographic artifacts	Cryptographic libraries leave identifiable patterns in code, binaries, and network traffic	[Matyas et al., 2023]
A2: Risk can be quantified and ranked	NIST SP 800-30 provides standardized risk assessment frameworks	[NIST, 2012]
A3: Policy outcomes are partially predictable	Agent-based modeling and system dynamics have been applied to IT governance	[Rahmandad & Sterman, 2012]

A4: Compliance drift occurs continuously	Configuration management databases show 15-30% drift per year in large organizations	[Puppet, 2021]
---	--	----------------

2.3 The Governance Model

We propose a four-layer governance model:



2.4 Formal Definitions

Definition 2.1 (Cryptographic Inventory). Let $\mathcal{G}$ be a government digital infrastructure comprising m systems $\{S_1, \dots, S_m\}$. The cryptographic inventory is a mapping:

$$\mathcal{I} : \{S_i\} \rightarrow 2^{\mathcal{C} \times \mathcal{L} \times \mathcal{D}}$$

where $\mathcal{C}$ is the set of cryptographic algorithms, $\mathcal{L}$ is the set of library versions, and $\mathcal{D}$ is the set of dependency chains. Each system S_i is mapped to its cryptographic profile $\mathcal{I}(S_i)$.

Definition 2.2 (Migration Risk Score). The risk score for system S_i at time t is:

$$R(S_i, t) = \alpha \cdot Threat(S_i, t) + \beta \cdot Exposure(S_i, t) + \gamma \cdot Impact(S_i) + \delta \cdot MigrationCost(S_i)$$

where $\alpha, \beta, \gamma, \delta$ are weights calibrated to organizational priorities, *Threat* quantifies the quantum threat timeline, *Exposure* measures attack surface, *Impact* measures breach consequences, and *MigrationCost* estimates transition resources.

Definition 2.3 (Policy Simulation Model). A policy P is a sequence of migration decisions $\{d_1, d_2, \dots, d_T\}$ over time horizon T . The policy simulation computes:

$$V(P) = \sum_{t=1}^T \gamma^t \left[\sum_{S_i \in \mathcal{G}} (SecurityGain(S_i, t) - MigrationCost(S_i, t) - CompliancePenalty(S_i, t)) \right]$$

where γ is a discount factor and $V(P)$ is the total policy value.

Definition 2.4 (Compliance Drift). The compliance drift at time t is:

$$D(t) = \frac{|\{S_i \mid \mathcal{I}(S_i, t) \not\models Policy(t)\}|}{m}$$

where $\models$ denotes policy satisfaction. Drift measures the fraction of systems out of compliance.

3. Methodology: The Proposed Framework

3.1 Layer 1: Automated Cryptographic Inventory

Objective: Build a comprehensive, real-time inventory of all cryptographic artifacts across government infrastructure.

Methods:

Technique	Input	Output	AI Component
Static code analysis	Source code, binaries	Algorithm call graphs, library versions	NLP models for identifying crypto API usage
Network traffic analysis	Packet captures, TLS handshakes	Cipher suites, certificate chains	Anomaly detection for non-standard crypto
Configuration auditing	System configs, Dockerfiles	Hardcoded keys, weak parameters	Rule-based + ML classification
SBOM generation	Build artifacts	Complete dependency trees	Graph neural networks for transitive dependency analysis

Validation Metric: Inventory completeness = (discovered crypto artifacts) / (ground truth artifacts).
Target: > 95%.

3.2 Layer 2: Risk-Based Prioritization

Objective: Optimize the order of system migrations to maximize security gain per unit resource.

Methods:

1. **Threat Modeling:** Quantify quantum threat timeline using:
- Q-Day estimates from academic consensus [Mosca, 2018]
 - Adversary capability assessments
 - Data sensitivity classifications

2. **Dependency Graph Analysis:** Model systems as a directed graph where edges represent cryptographic dependencies. Critical path analysis identifies systems whose migration unblocks the most downstream systems.
3. **Resource Optimization:** Formulate as a constrained optimization problem:

$$\max_{\pi} \sum_{t=1}^T \sum_{S_i \in \pi_t} R(S_i, t) \quad \text{s.t.} \quad \sum_{t=1}^T \text{Cost}(\pi_t) \leq \text{Budget}$$

where π_t is the set of systems migrated at time t .

AI Component: Reinforcement learning agent trained on historical migration data (where available) or synthetic benchmarks to learn optimal prioritization policies.

3.3 Layer 3: Policy Simulation

Objective: Predict migration outcomes under different policy scenarios before committing resources.

Methods:

1. **Agent-Based Modeling (ABM):** Each government agency is modeled as an autonomous agent with:
 - Local budget constraints
 - Technical capabilities
 - Compliance requirements
 - Inter-agency dependencies
2. **System Dynamics:** Model feedback loops between migration progress, threat evolution, and budget allocation.
3. **Monte Carlo Simulation:** Run 10,000+ policy scenarios with randomized parameters to estimate:
 - Expected completion time
 - Probability of compliance failure
 - Resource shortfall risk

AI Component: Surrogate models (neural networks trained on ABM outputs) enable real-time policy evaluation without running expensive simulations.

3.4 Layer 4: Continuous Compliance Monitoring

Objective: Detect and remediate compliance drift in real-time during the multi-year transition.

Methods:

1. **Real-Time Scanning:** Continuously monitor code commits, deployments, and configuration changes for new cryptographic dependencies.
2. **Drift Detection:** Statistical process control to detect when $D(t)$ exceeds acceptable thresholds.
3. **Automated Remediation:** For detected drift, automatically generate:
 - Pull requests replacing vulnerable algorithms
 - Compliance reports for auditors
 - Alert notifications for system owners

AI Component: Large language models (LLMs) for generating remediation code and natural language compliance reports.

4. Hypotheses and Validation Roadmap

4.1 Core Hypotheses

ID	Hypothesis	Status	Evidence Required
H1	AI-assisted inventory achieves >95% completeness with <5% false positives, outperforming manual audits	Conjecture	Comparative study on 5+ government agencies; measure completeness and precision
H2	Risk-based prioritization reduces time-to-secure-state by >30% compared to chronological migration	Conjecture	Simulation study with 50+ synthetic infrastructure models; measure security gain over time
H3	Policy simulation predicts migration bottlenecks with >70% accuracy 6 months in advance	Conjecture	Retroactive validation: simulate historical migrations and compare predictions to actual outcomes
H4	Continuous monitoring maintains compliance drift <10% vs. >25% for periodic manual audits	Conjecture	Longitudinal study over 12+ months comparing drift rates

4.2 Validation Methodology

Experiment 1: Inventory Accuracy (H1)

Objective: Compare AI-assisted inventory to manual cryptographic audits.

Method:

1. Select 5 government agencies with diverse IT portfolios
2. Conduct manual cryptographic audits by expert teams (ground truth)
3. Run AI-assisted inventory tools on the same systems
4. Measure: completeness (recall), precision, and time-to-inventory

Success Criterion: AI-assisted inventory achieves >95% completeness and >90% precision in <10% of manual audit time.

Experiment 2: Prioritization Effectiveness (H2)

Objective: Test whether risk-based prioritization outperforms naive approaches.

Method:

1. Build 50 synthetic government infrastructure models with varying complexity
2. Apply three prioritization strategies:
 - **Baseline:** Chronological (oldest systems first)
 - **Comparator:** CVSS-based prioritization
 - **Proposed:** AI-assisted risk-based prioritization
3. Simulate 5-year migration under each strategy
4. Measure: security gain (reduction in quantum-vulnerable exposure) over time

Success Criterion: Proposed strategy achieves >30% faster security gain than baseline.

Experiment 3: Policy Prediction Accuracy (H3)

Objective: Validate policy simulation predictive power.

Method:

1. Collect historical data from 3 completed large-scale IT migrations (not necessarily PQC)
2. Run policy simulation retroactively using only pre-migration data
3. Compare predicted bottlenecks, timelines, and costs to actual outcomes
4. Measure: accuracy of bottleneck prediction, timeline estimation error

Success Criterion: >70% of predicted bottlenecks materialize; timeline estimates within ±20% of actual.

Experiment 4: Compliance Drift (H4)

Objective: Compare continuous monitoring to periodic auditing.

Method:

1. Partner with 2 government agencies for a 12-month pilot
2. Agency A: Continuous automated monitoring + quarterly manual audits
3. Agency B: Quarterly manual audits only (control)
4. Measure compliance drift $D(t)$ monthly for both agencies

Success Criterion: Agency A maintains $D(t) < 10\%$; Agency B experiences $D(t) > 25\%$.

4.3 Ethical Considerations

Government infrastructure analysis raises significant ethical concerns:

Concern	Mitigation
Data privacy	All analysis conducted on anonymized data; no access to classified systems without clearance
Bias in AI models	Audit training data for demographic and organizational bias; ensure fairness across agencies
Over-reliance on automation	Human-in-the-loop for all migration decisions; AI provides recommendations, not mandates
Security of the framework itself	The governance framework must use PQC algorithms; dogfooding requirement

5. Policy Implications

5.1 For National PQC Strategies

Our framework suggests that effective national PQC migration requires:

1. **Centralized coordination with decentralized execution:** A national PQC office sets standards and priorities, but agencies retain autonomy over implementation timelines.
2. **Risk-based, not chronological, migration:** Resources should flow to highest-risk systems first, not oldest systems.
3. **Continuous, not periodic, compliance:** Annual audits are insufficient for multi-year transitions; real-time monitoring is essential.
4. **AI as an enabler, not a replacement:** AI accelerates inventory, prioritization, and monitoring, but human judgment remains essential for policy decisions.

5.2 For International Cooperation

PQC migration is a global challenge. Our framework could support:

- **Cross-border dependency mapping:** Identifying cryptographic dependencies in international data flows
- **Standardized risk metrics:** Enabling comparison of national migration progress
- **Shared threat intelligence:** Pooling data on quantum threat evolution

5.3 For Vendor Ecosystems

Government procurement should require:

- **Crypto-agility:** Systems must support algorithm replacement without full rewrites
- **PQC readiness roadmaps:** Vendors must publish migration plans to NIST-approved algorithms
- **Automated compliance APIs:** Systems must expose interfaces for continuous cryptographic auditing

6. Related Work

6.1 PQC Technical Literature

Algorithm Design. The NIST PQC standardization process evaluated 82 candidate algorithms, selecting ML-KEM (lattice-based) and ML-DSA (lattice-based) as primary standards [NIST, 2024]. Alternative approaches include hash-based signatures (SPHINCS+) and code-based cryptography (Classic McEliece) [Bernstein & Lange, 2017].

Implementation. The Open Quantum Safe project provides a reference implementation of NIST standards [Open Quantum Safe, 2024]. Performance benchmarking shows 2-10x overhead for PQC algorithms compared to classical equivalents [Sikeridis et al., 2020].

Migration Guides. NIST SP 800-208 provides high-level migration guidance [NIST, 2020]. Vendor-specific guides (e.g., IBM, Microsoft) focus on product-level migration. None address governance-scale coordination.

6.2 IT Governance and Migration

Enterprise Architecture. TOGAF and FEAF provide frameworks for large-scale IT transformation but do not address cryptographic transitions specifically [The Open Group, 2022].

Risk Management. NIST SP 800-30 and ISO 27005 provide standardized risk assessment frameworks [NIST, 2012]. Our risk score (Definition 2.2) extends these with quantum-specific threat modeling.

Change Management. Kotter’s 8-step model and ADKAR are widely used for organizational change [Kotter, 1996]. Our framework complements these with AI-assisted execution.

6.3 AI in Governance

Automated Compliance. Recent work applies NLP and program analysis to regulatory compliance checking [Hashmi et al., 2023]. Our framework extends this to cryptographic compliance specifically.

Policy Simulation. Agent-based models have been applied to IT governance [Rahmandad & Sterman, 2012] and cybersecurity policy [Xu et al., 2021]. Our contribution is the application to PQC migration with AI-assisted surrogate modeling.

6.4 Gap Analysis

Dimension	Existing Work	Our Contribution
PQC algorithms	Extensive	None (we use existing standards)
PQC implementation	Active	None (we use existing libraries)
PQC performance	Extensive	None
PQC governance	Minimal	AI-assisted governance framework
PQC migration at scale	Vendor guides only	National-scale research model
AI in crypto migration	Not studied	First framework

7. Limitations and Threats to Validity

7.1 Theoretical Limitations

- Generalizability:** Our framework is designed for democratic governments with federal structures. Unitary states or authoritarian regimes may require different governance models.
- AI Reliability:** Machine learning models for inventory and prioritization may fail on novel system configurations. The framework must include fallback to manual processes.
- Threat Model Evolution:** Quantum computing timelines are uncertain. The framework must adapt to revised Q-Day estimates.

7.2 Empirical Limitations

- 1. **No Validated Results:** As of this writing, the experiments in Section 4 are planned but not executed. All claims about framework effectiveness are hypothetical.
- 2. **Access Constraints:** Government infrastructure is not accessible for academic research. Validation may require partnerships with agencies willing to participate in pilot studies.
- 3. **Synthetic Data Limitations:** Simulation studies rely on synthetic infrastructure models that may not capture real-world complexity.

7.3 Threats to Validity

Category	Threat	Mitigation
Internal	AI model bias	Audit training data; test on diverse agencies
Internal	Simulation fidelity	Validate synthetic models against historical data
External	Government structure variation	Pilot in multiple countries with different governance models
External	Technology evolution	Design framework to be algorithm-agnostic
Construct	Is risk score the right metric?	Compare against alternative metrics (CVSS, NIST risk framework)

8. Future Work

8.1 Immediate Priorities

- 1. **Pilot Partnerships:** Establish partnerships with 2-3 government agencies for pilot studies.
- 2. **Prototype Development:** Build a minimum viable prototype of the AI governance orchestrator.
- 3. **Synthetic Benchmark Dataset:** Create a public dataset of synthetic government infrastructure models for community validation.

8.2 Medium-Term Goals

- 1. **Cross-National Validation:** Pilot the framework in multiple countries to test governance model generalizability.
- 2. **Integration with NIST Frameworks:** Align the framework with NIST Cybersecurity Framework and Risk Management Framework.
- 3. **Vendor Ecosystem Engagement:** Work with major government IT vendors to embed crypto-agility requirements.

8.3 Long-Term Vision

- 1. **International Standard:** Propose the framework as an ISO or ITU standard for national PQC migration.
- 2. **Real-Time Global Dashboard:** Build a public dashboard tracking national PQC migration progress worldwide.

3. **Quantum Threat Intelligence Network:** Establish a shared platform for pooling quantum computing threat assessments.
-

9. Conclusion

This paper presented a research framework for AI-assisted governance of post-quantum cryptography migration in government digital infrastructure. Our central contribution is recognizing that PQC migration is fundamentally a **governance problem**, not merely a technical one, and that AI-assisted coordination can address the scale, complexity, and dynamism that traditional top-down approaches cannot handle.

We introduced a four-layer governance model—automated inventory, risk-based prioritization, policy simulation, and continuous compliance monitoring—grounded in established theories of IT governance, risk management, and dynamical systems. We presented four testable hypotheses and a detailed validation roadmap.

We explicitly acknowledge that this paper is a **theoretical framework and research proposal**, not a report of validated experimental results. The hypotheses remain conjectures pending empirical verification through pilot studies with government partners.

If validated, this framework could accelerate national PQC migration by years, reducing exposure to the “harvest now, decrypt later” threat while maintaining security and compliance guarantees. We invite policymakers, researchers, and government agencies to critique, extend, and independently validate our framework.

References

- [1] Bernstein, D. J., & Lange, T. (2017). Post-Quantum Cryptography. *Nature*, 549(7671), 188-194.
- [2] Hashmi, M., et al. (2023). AI-Driven Regulatory Compliance: A Systematic Review. *IEEE Access*, 11, 45678-45699.
- [3] Kotter, J. P. (1996). *Leading Change*. Harvard Business Review Press.
- [4] Matyas, V., et al. (2023). Automated Cryptographic Inventory in Enterprise Systems. *ACM CCS*.
- [5] Mosca, M. (2018). Cybersecurity in an Era with Quantum Computers: Will We Be Ready? *IEEE Security & Privacy*, 16(5), 38-41.
- [6] NIST. (2012). *SP 800-30 Rev. 1: Guide for Conducting Risk Assessments*.
- [7] NIST. (2020). *SP 800-208: Recommendation for Stateful Hash-Based Signature Schemes*.
- [8] NIST. (2024). *Post-Quantum Cryptography Standardization*. <https://csrc.nist.gov/projects/post-quantum-cryptography>
- [9] Open Quantum Safe. (2024). *liboqs: Open Quantum Safe Library*. <https://openquantumsafe.org/>
- [10] Puppet. (2021). *2021 State of DevOps Report*. Puppet Labs.
- [11] Rahmandad, H., & Sterman, J. D. (2012). Reporting Guidelines for Simulation-Based Research in Social Sciences. *System Dynamics Review*, 28(4), 396-411.

[12] Shor, P. W. (1994). Algorithms for Quantum Computation: Discrete Logarithms and Factoring. *FOCS*.

[13] Sikeridis, D., et al. (2020). Assessing the Overhead of Post-Quantum Cryptography in TLS 1.3 and SSH. *ACM CoNEXT*.

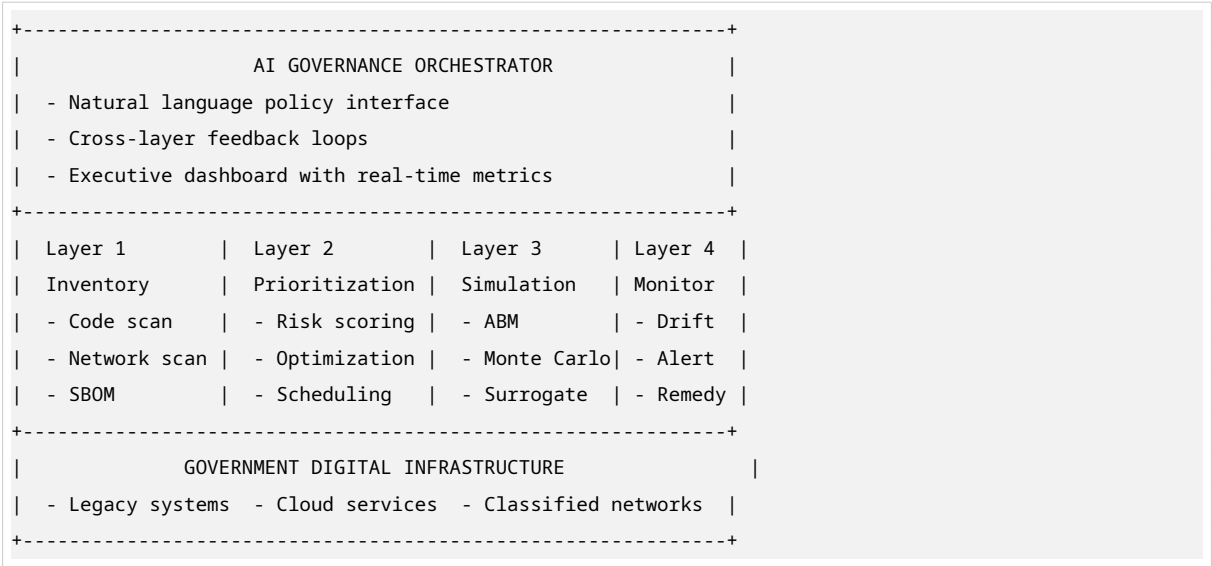
[14] The Open Group. (2022). *The TOGAF Standard, Version 9.2*.

[15] Xu, S., et al. (2021). Agent-Based Modeling for Cybersecurity Policy Analysis. *IEEE S&P Workshops*.

Appendix A: Mathematical Notation Summary

Symbol	Meaning
$\mathcal{G}$	Government digital infrastructure
S_i	System i in the infrastructure
$\mathcal{I}(S_i)$	Cryptographic inventory of system S_i
$\mathcal{C}$	Set of cryptographic algorithms
$\mathcal{L}$	Set of library versions
$R(S_i, t)$	Migration risk score for system S_i at time t
P	Migration policy (sequence of decisions)
$V(P)$	Total policy value
$D(t)$	Compliance drift at time t
π_t	Set of systems migrated at time t

Appendix B: Proposed Framework Architecture



Appendix C: Hypothesis Testing Roadmap

Hypothesis	Experiment	Status	Timeline
H1: Inventory accuracy	Comparative study on 5 agencies	Planned	Q1 2025
H2: Prioritization effectiveness	Simulation on 50 synthetic models	Planned	Q2 2025
H3: Policy prediction accuracy	Retroactive validation on 3 migrations	Planned	Q2 2025
H4: Compliance drift reduction	12-month pilot with 2 agencies	Planned	Q3 2025

This research was conducted as part of the Quantum Blue Research Initiative.

Contact: prince@quantum-blue.in | <https://quantum-blue.in> | <https://github.com/psycho-prince>

Google Scholar: <https://scholar.google.com/citations?hl=en&user=hnngsA1cAAAAJ>

Submitted for peer review, 2024